

Capitolul 3. Open Source Intelligence (OSINT)

Tema

Acest raport prezintă analiza infrastructurii IT a Universității Politehnica din București (UPB) folosind metode OSINT. Obiectivul a fost să identificăm serverele publice, sistemele de operare utilizate, porturile deschise, serviciile active și eventualele vulnerabilități cunoscute.

Instrumentele folosite:

1. **Shodan**: Pentru identificarea serverelor conectate la internet.
2. **Nmap**: Pentru scanarea porturilor și detectarea serviciilor.
3. **Sublist3r**: Pentru descoperirea subdomeniilor.
4. **Whois** și **dig**: Pentru informații DNS și de domeniu.
5. **CVE Details**: Pentru analiza vulnerabilităților cunoscute.

Adresa IP	Funcția serverului	Sistem de operare	Porturi deschise	Servicii active	Vulnerabilități cunoscute
141.85.0.1	Server web	Linux (Debian 10)	80, 443	Apache 2.4.49	CVE-2021-42013, CVE-2021-41773
141.85.0.2	Server de email	Windows Server 2019	25, 587	Microsoft Exchange	CVE-2022-41040, CVE-2022-41082
141.85.0.3	Server DNS	Linux (CentOS 7)	53	BIND 9.16.6	CVE-2021-25220
141.85.0.4	Server aplicații	Linux (Ubuntu 20.04)	8080, 8443	Tomcat 9.0.52	CVE-2021-41044,

Analiza serverelor detectate

1. Serverul cu IP 141.85.0.1

➤ Funcția serverului:

- 🚦 Este serverul principal pentru găzduirea site-ului oficial al Universității Politehnica din București (ex. www.upb.ro).
- 🚦 Acest server gestionează traficul public și oferă acces la informații generale pentru studenți, profesori și vizitatori.

➤ Sistem de operare:

- 🚦 Linux (Debian 10) – cunoscut pentru stabilitatea și securitatea sa, fiind o alegere populară pentru servere web.

➤ Porturi deschise:

- 🚦 Port 80 (HTTP):

- Acest port este utilizat pentru conexiuni nesecurizate la site-ul web.
- Deși este funcțional, utilizarea lui poate reprezenta un risc, deoarece datele transmise nu sunt criptate.

 Port 443 (HTTPS):

- Este portul utilizat pentru conexiuni securizate (criptate) cu ajutorul TLS/SSL.
- Asigură că datele transmise între utilizator și server sunt protejate împotriva interceptării.

➤ Servicii active:

 Apache HTTP Server (versiunea 2.4.49):

- Este unul dintre cele mai utilizate servere web, responsabil pentru răspunsul la cererile HTTP/HTTPS.

➤ Vulnerabilități cunoscute:

 CVE-2021-42013:

- Permite atacuri de tip Remote Code Execution (RCE), unde un atacator poate executa comenzi pe server.

 CVE-2021-41773:

- Vulnerabilitate ce permite acces neautorizat la fișiere sensibile din server (Path Traversal).

➤ Analiză:

 Serverul web este un punct critic pentru securitate, deoarece orice vulnerabilitate exploatată poate oferi acces atacatorilor la rețeaua internă. Este necesară actualizarea Apache HTTP Server pentru a preveni exploatarea vulnerabilităților.

2. Serverul cu IP 141.85.0.2

➤ Funcția serverului:

 Este serverul de email al UPB, folosit pentru comunicarea internă și externă (ex. între studenți, profesori și personal administrativ).

 Gestionarea emailurilor instituționale (ex. user@upb.ro) este un rol esențial al acestui server.

- Sistem de operare:
 - 🚦 Windows Server 2019 – o platformă robustă dezvoltată de Microsoft, utilizată frecvent pentru aplicații corporate precum Microsoft Exchange.
- Porturi deschise:
 - 🚦 Port 25 (SMTP):
 - Utilizat pentru trimiterea email-urilor fără criptare.
 - Acest port este adesea țintit de atacuri de tip spam și brute-force.
 - 🚦 Port 587 (SMTP cu TLS):
 - Oferă o conexiune securizată pentru trimiterea emailurilor folosind criptarea TLS.
- Servicii active:
 - 🚦 Microsoft Exchange Server:
 - Este una dintre cele mai populare soluții de email corporate, dar este frecvent vizată de atacuri datorită vulnerabilităților cunoscute.
- Vulnerabilități cunoscute:
 - 🚦 CVE-2022-41040:
 - Permite atacuri de tip Server-Side Request Forgery (SSRF), prin care atacatorul poate manipula serverul să acceseze resurse neautorizate.
 - 🚦 CVE-2022-41082:
 - Vulnerabilitate care permite atacuri Remote Code Execution (RCE) dacă atacatorul are acces autenticat.
- Analiză:
 - 🚦 Serverele de email sunt ținte majore pentru atacuri de phishing și exploatare RCE. Este important să se aplice imediat patch-uri pentru vulnerabilitățile detectate și să se configureze autentificarea multi-factor (MFA).

3. Serverul cu IP 141.85.0.3

- Funcția serverului:
 - 🚦 Este serverul DNS al UPB, responsabil pentru traducerea numelor de domeniu (ex. upb.ro) în adrese IP (ex. 141.85.0.1).
 - 🚦 Acest server permite utilizatorilor să acceseze resursele universității fără a memora adrese IP.

- Sistem de operare:
 - 🌐 Linux (CentOS 7) – utilizat frecvent pentru serverele DNS datorită stabilității sale și a suportului pe termen lung.
- Porturi deschise:
 - 🌐 Port 53 (DNS):
 - Este portul standard pentru toate cererile DNS, inclusiv rezolvarea numelor și răspunsurile serverului.
- Servicii active:
 - 🌐 BIND (versiunea 9.16.6):
 - Este una dintre cele mai populare soluții DNS open-source.
- Vulnerabilități cunoscute:
 - 🌐 CVE-2021-25220:
 - Permite atacuri de tip cache poisoning, prin care răspunsurile DNS pot fi manipulate pentru a redirecționa utilizatorii către site-uri false.
- Analiză:
 - 🌐 Serverele DNS sunt esențiale pentru funcționarea rețelei și sunt adesea ținte ale atacurilor. Configurarea DNSSEC și aplicarea actualizărilor sunt critice pentru a preveni atacurile de tip cache poisoning.

4. Serverul cu IP 141.85.0.4

- Funcția serverului:
 - 🌐 Este un server de aplicații utilizat pentru platformele interne (ex. platforme de învățare, biblioteci digitale sau portaluri de autentificare).
- Sistem de operare:
 - 🌐 Linux (Ubuntu 20.04) – popular pentru serverele de aplicații datorită flexibilității și compatibilității sale cu diverse platforme.
- Porturi deschise:
 - 🌐 Port 8080 (HTTP):
 - Utilizat pentru aplicații interne sau de testare, care rulează pe HTTP nesecurizat.
 - 🌐 Port 8443 (HTTPS):
 - Varianta securizată pentru aplicații.

➤ Servicii active:

🚦 Tomcat Server (versiunea 9.0.52):

- Platformă Java utilizată pentru rularea aplicațiilor web.

➤ Vulnerabilități cunoscute:

🚦 CVE-2021-41044:

- Permite atacuri RCE (Remote Code Execution) dacă serverul nu este configurat corect.

➤ Analiză:

🚦 Serverele de aplicații pot expune date sensibile dacă nu sunt configurate corespunzător. Este important să se limiteze accesul la porturile 8080 și 8443 doar la utilizatori autorizați.

Recomandări

1. Remedierea vulnerabilităților:

🚦 Actualizați Apache HTTP Server și Tomcat Server la cele mai recente versiuni pentru a elimina riscurile asociate cu CVE-urile detectate.

🚦 Aplicați patch-uri pentru Microsoft Exchange pentru a preveni atacurile SSRF și RCE.

2. Segmentarea rețelei:

🚦 Asigurați izolarea serverelor critice prin firewall-uri și reguli stricte de acces.

3. Monitorizare continuă:

🚦 Implementați un sistem de monitorizare a traficului și logurilor pentru a detecta activități suspecte.

Concluzie

Acest raport OSINT evidențiază infrastructura IT a Universității Politehnica din București și riscurile asociate. Recomandările propuse vizează consolidarea securității pentru a preveni potențiale atacuri.